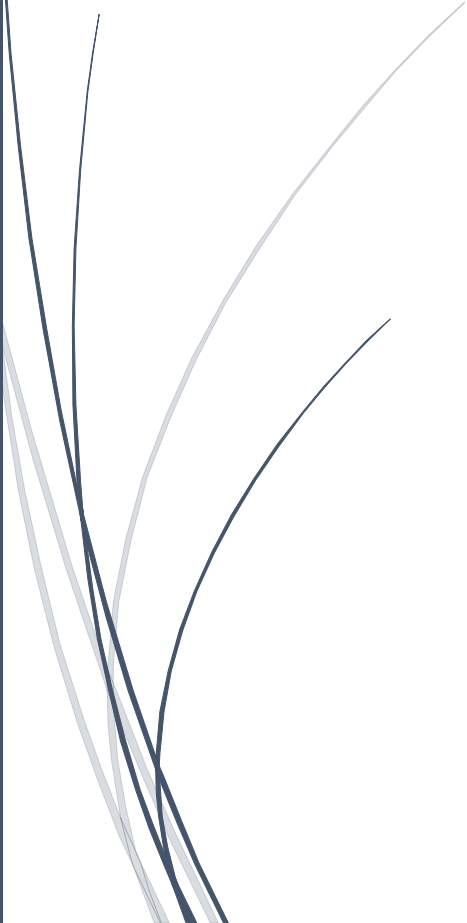


A dark blue vertical bar runs down the left side of the page. A blue arrow points to the right from this bar, containing the date.

11/04/2025

Plan d'action

Client : Clinique de Frontignan

Several thin, curved lines in dark blue and light grey originate from the bottom left corner and sweep upwards and to the right.

Walid Rhouma

I. Plan d'action à court terme :

Dans le cadre de l'amélioration de la sécurité du système d'information, il est essentiel d'adopter des mesures concrètes et immédiates pour corriger les vulnérabilités identifiées lors de l'audit de sécurité. Ce plan d'action à court terme se concentre sur des recommandations permettant de réduire rapidement les risques critiques et d'assurer une défense renforcée face aux menaces potentielles. Chaque recommandation est liée à une vulnérabilité spécifique, avec des actions pratiques à réaliser et des priorités claires afin de maximiser l'impact de ces améliorations en un minimum de temps. En mettant en œuvre ces mesures, nous garantissons une résilience accrue du système tout en préparant les bases pour des actions à long terme plus stratégiques.

Le plan couvre des aspects clés comme la gestion des mots de passe, la sécurisation des comptes, la surveillance active, et la mise en conformité avec les bonnes pratiques de sécurité. Chaque recommandation est accompagnée des ressources nécessaires pour aider à la mise en œuvre, assurant ainsi une transition fluide vers un environnement plus sécurisé.

Recommandation R01 : Mettre en place une politique de mots de passe forte

- **Vulnérabilités corrigées : V04, V06, V08**
- **Ordre de priorité : Priorité 1/3**
- **Actions à réaliser :**
 - Modifier immédiatement les mots de passe des comptes compromis
 - Révoquer toutes les sessions actives utilisant ces comptes
 - Exiger des mots de passe d'au moins 12 caractères et complexes (minuscules, majuscules, chiffres et caractères spéciaux)
 - Appliquer une expiration des mots de passe tous les 90 jours
 - Interdire la réutilisation des 5 derniers mots de passe
 - Exiger l'activation de **LAPS** (Local Administrator Password Solution) pour les comptes administrateurs locaux.
- **Ressources :**
 - <https://www.it-connect.fr/politique-de-mot-de-passe-comment-appliquer-les-bonnes-pratiques-de-lanssi/>
 - <https://www.cnil.fr/fr/mots-de-passe-une-nouvelle-recommandation-pour-maitriser-sa-securite>

Afin de renforcer la sécurité des comptes utilisateurs, il est recommandé de mettre en place une politique de mots de passe stricte. Cela implique de changer les mots de passe compromis, de révoquer les sessions actives associées, et d'imposer des mots de passe d'au moins 12 caractères, incluant majuscules, minuscules, chiffres et caractères spéciaux.

Les mots de passe devront expirer tous les 90 jours, la réutilisation des 5 derniers sera interdite, et LAPS devra être activé pour sécuriser les comptes administrateurs locaux.

Recommandation R02 : Mettre en place une politique de verrouillage de comptes

- **Vulnérabilités corrigées : V05, V06**
- **Ordre de priorité : Priorité 1/3**
- **Actions à réaliser :**
 - Activer la politique de verrouillage de comptes après X tentatives de connexions
 - Définir un délai de déverrouillage automatique (ex : 30 minutes)
 - Surveiller les journaux pour détecter tout comportement suspect (ex : brute force)
- **Ressources :**
 - <https://learn.microsoft.com/en-us/previous-versions/windows/it-pro/windows-10/security/threat-protection/security-policy-settings/account-lockout-policy>

Le fait que les comptes ne soient pas verrouillés après plusieurs échecs permet aux attaquants de tester indéfiniment des mots de passe en utilisant des techniques de brute-force et password spraying par exemple. L'application de cette mesure bloquera les attaques automatisées de type password spraying et brute-force sur les comptes utilisateurs et administrateurs..

Recommandation R03 : Supprimer les mots de passe en clair dans les descriptions LDAP

- **Vulnérabilité corrigée : V07**
- **Ordre de priorité : Priorité 1/3**
- **Actions à réaliser :**
 - Procéder à une vérification des attributs "Description" des objets LDAP
 - Supprimer toute donnée sensible exposée
 - Sensibiliser les administrateurs à ne jamais écrire d'informations critique dans les descriptions

La présence de mots de passe en clair dans les descriptions LDAP constitue une faille critique exploitable par un attaquant ayant un accès en lecture à l'annuaire. Ces informations sensibles et souvent négligées, peuvent permettre un accès non autorisé à des ressources internes compromettant ainsi l'ensemble du système d'information.

Supprimer ces données et sensibiliser les administrateurs à de bonnes pratiques documentaire est donc une priorité pour limiter les risques de compromission liés à une mauvaise gestion des métadonnées de l'Active Directory.

Recommandation R04 : Désactiver les comptes inutilisés ou obsolètes

- **Vulnérabilité corrigée : V04**
- **Ordre de priorité : Priorité 1/3**
- **Actions à réaliser :**
 - Identifier et désactiver les comptes utilisateur et service non utilisés.
 - Supprimer les comptes invités
 - Désactiver les comptes de test, comme celui utilisé dans l'attaque "user-as-pass", qui n'ont pas été supprimés après leur utilisation.
 - Mettre en place une revue régulière des comptes AD pour s'assurer de leurs pertinence.

Les comptes inutilisés, y compris les comptes de test, représentent des portes d'entrée potentielles pour les attaquants. L'attaque exploitant le compte test montre qu'un mot de passe faible, tel que "test", rend le système vulnérable à des attaques automatisées. En désactivant ces comptes et en appliquant une gestion stricte, on limite les risques d'accès non autorisés et de compromission du domaine..

Recommandation R05 : Sécuriser les comptes de services contre le Kerberoasting

- **Vulnérabilité corrigée : V09**
- **Ordre de priorité : Priorité 2/3**
- **Actions à réaliser :**
 - Migrer autant que possible les services vers des comptes machines, qui bénéficient de mots de passe longs générés automatiquement.
 - Lorsque l'usage de comptes utilisateurs est nécessaire, privilégier les *Managed Service Accounts (MSA)* ou *Group Managed Service Accounts (gMSA)*, assurant une gestion sécurisée et automatisée des mots de passe
 - Appliquer une politique de mot de passe rigoureuse et limiter strictement les droits des comptes de service selon le principe du moindre privilège.
 - Mettre en place une surveillance active des tickets Kerberos et des Service Principal Names (SPN) pour détecter toute activité suspecte.
- **Ressources :**
 - <https://specopssoft.com/fr/blog/kerberoasting-comment-assurer-la-securite-de-votre-active-directory/>

Les comptes de service mal protégés sont une porte d'entrée privilégiée pour les attaques Kerberoasting. En chiffrant leurs tickets Kerberos avec un mot de passe faible ou réutilisé, ils exposent tout le domaine en cas de compromission.

Sécuriser ces comptes, utiliser des mécanismes de gestion automatique de mot de passe, et surveiller les activités liées aux SPN sont des mesures indispensables pour limiter le risque.

Recommandation R06 : Sécuriser LDAP avec LDAPS (port 636)

- **Vulnérabilité corrigée : V02**
- **Ordre de priorité : Priorité 2/3**
- **Actions à réaliser :**
 - Désactiver le port 389 sur le contrôleur de domaine.
 - Forcer LDAPS (port 636) avec un certificat TLS/SSL valide.
 - Désactiver l'accès anonyme et restreindre les utilisateurs pouvant interroger l'annuaire
 - Modifier la configuration des applications utilisant LDAP pour utiliser LDAPS.
- **Ressources :**
 - <https://www.it-connect.fr/active-directory-configurer-ldaps-certificat-autosigne/>

L'utilisation de LDAP en clair permet aux attaquants d'intercepter des identifiants et d'effectuer des requêtes anonymes pour récupérer des informations sensibles. L'absence de chiffrement expose donc les authentifications des utilisateurs et administrateurs. Appliquer cette mesure réduira le risque d'interception des identifiants et protégera les communications avec l'Active Directory.

Recommandation 07 : Activer le SMB signing sur toutes les machines

- **Vulnérabilité corrigée : V03**
- **Ordre de priorité : Priorité 2/3**
- **Actions à réaliser :**
 - Appliquer un GPO qui activera le SMB signing sur les clients et serveurs du domaine
 - Vérifier que la configuration est appliquée via la commande gpresult
- **Ressources :**
 - <https://firesecure.fr/activer-les-signatures-smb/>

L'activation de SMB Signing sur l'ensemble des machines du domaine garantit l'intégrité des communications SMB entre les clients et les serveurs. En imposant cette signature par le biais des stratégies de groupe (GPO), on protège contre les attaques de type Man-in-the-Middle (MiTM), telles que la falsification de paquets ou la capture de sessions, en s'assurant que chaque message échangé est authentifié.

Recommandation R08 : Segmenter le réseau pour limiter les mouvements latéraux

- **Vulnérabilité corrigée : V01**
- **Ordre de priorité : Priorité 2/3**
- **Actions à réaliser :**
 - Mettre en place des VLAN dédiés (VLAN utilisateurs, VLAN administration, VLAN serveurs,...)
 - Appliquer des ACL pour gérer les flux inter-VLAN
 - Appliquer des règles de pare-feu strictes
- **Ressources :**
 - <https://openclassrooms.com/fr/courses/7192261-simulez-le-schema-de-votre-reseau-avec-cisco-packet-tracer/7444275-utilisez-les-vlan-pour-reduire-vos-domaines-de-diffusion>
 - <https://www.it-connect.fr/les-listes-de-controle-dacces-acl-avec-cisco/>

Actuellement, tous les équipements peuvent communiquer sans restriction, ce qui facilite la propagation latérale en cas de compromission d'un poste. Une segmentation efficace empêchera un attaquant d'accéder directement aux serveurs critiques. Cette mesure améliorera la résilience du réseau face aux attaques internes et externes.

Recommandation R09 : Appliquer les correctifs de sécurité sur tous les équipements

- **Vulnérabilités corrigées : V01, V02, V03, V05, V06, V09**
- **Ordre de priorité : Priorité 2/3**
- **Actions à réaliser :**
 - Appliquer les dernières mises à jour Windows Server et systèmes clients.
 - Vérifier la présence de correctifs spécifiques aux vulnérabilités SMB, LDAP, Kerberos et autres services impactés
 - Mettre en place une solution de gestion centralisée des mises à jour (WSUS ou SCCM) afin de faciliter le déploiement des patches sur l'ensemble du réseau.
- **Ressources :**
 - <https://www.it-connect.fr/chapitres/qu-est-ce-qu-un-serveur-wsus/>
 - <https://www.ninjaone.com/fr/blog/sccm-vs-wsus-ce-que-vous-devez-savoir/>

L'absence d'application des correctifs de sécurité expose les systèmes à des vulnérabilités connues, susceptibles d'être exploitées par des attaquants pour compromettre les services ou obtenir un accès non autorisé. L'application régulière des patches renforce la sécurité en éliminant ces failles et en améliorant la stabilité des systèmes. En intégrant un processus de mise à jour centralisé, il devient possible de gérer efficacement la sécurité de l'ensemble du réseau et de réduire les risques de cyberattaques en fermant les portes laissées ouvertes par des systèmes non corrigés.

Recommandation R10 : Mettre en place une surveillance active avec un SIEM

- **Vulnérabilités corrigées : V04, V05, V06, V07, V08**
- **Ordre de priorité : Priorité 2/3**
- **Actions à réaliser :**
 - Installer un SIEM (Security Information and Event Management) comme l'outil Splunk pour centraliser et analyser les logs.
 - Activer l'audit des tentatives de connexion échouées et les alertes sur les activités suspectes.
- Configurer des alertes en cas de comportements anormaux (ex : connexions simultanées sur plusieurs machines).
- **Ressources :**
 - <https://www.microsoft.com/fr-fr/security/business/security-101/what-is-siem>
 - https://www.splunk.com/en_us/blog/learn/siem-security-information-event-management.html

L'absence de surveillance laisse le réseau vulnérable aux intrusions et aux comportements malveillants non détectés. L'implémentation d'un SIEM permet de repérer rapidement les activités suspectes et de réagir efficacement aux incidents de sécurité. La centralisation des logs permet ainsi une analyse plus efficace.

II. Plan d'action à long terme :

Le plan d'action à long terme s'inscrit dans une stratégie continue d'amélioration de la sécurité du système d'information. Après avoir mis en place des actions correctrices immédiates, il devient crucial d'implémenter des mesures qui garantissent une sécurité durable et proactive. Ce plan s'articule autour de recommandations visant à renforcer la gestion des accès privilégiés, à sensibiliser les utilisateurs aux risques de cybersécurité et à instaurer des audits réguliers pour maintenir une vigilance constante. Ces actions permettront de limiter les risques à long terme en assurant une surveillance continue, en formant les utilisateurs et en effectuant des vérifications régulières des infrastructures. Les recommandations ici présentées sont cruciales pour établir une base solide de sécurité sur le long terme, tout en adaptant les pratiques aux évolutions des menaces.

Recommandation R11 : Mettre en place une gestion des accès privilégiés (PAM)

- **Vulnérabilité corrigée : V09**
- **Ordre de priorité : Priorité 3/3**
- **Actions à réaliser :**
 - Mettre en place un PAM (Privileged Access Management) pour restreindre et surveiller les accès administrateurs.
 - Activer le principe du moindre privilège pour tous les comptes.
 - Limiter les connexions RDP aux comptes ayant un réel besoin.
- **Ressources :**
 - <https://www.microsoft.com/fr-fr/security/business/security-101/what-is-privileged-access-management-pam>

Les comptes à privilèges sont des cibles de choix pour les attaquants. Un manque de contrôle sur ces accès peut entraîner une compromission critique du système. L'implémentation d'un PAM réduit ces risques en limitant et en surveillant l'utilisation des privilèges élevés.

Recommandation R12 : Sensibiliser les utilisateurs aux bonnes pratiques de sécurité

- **Vulnérabilités corrigées : V04, V07**
- **Ordre de priorité : Priorité 3/3**
- **Actions à réaliser :**
 - Organiser des sessions de formation régulières sur les bonnes pratiques de cybersécurité.
 - Sensibiliser les utilisateurs sur les risques du phishing et de l'ingénierie sociale.
 - Mettre en place des campagnes de test de phishing pour évaluer la vigilance des employés.
- **Ressources :**

Les attaques par phishing et ingénierie sociale exploitent la méconnaissance des utilisateurs pour compromettre un système. Une sensibilisation active permet de réduire ces risques en rendant les employés plus vigilants face aux menaces.

Recommandation R13 : Réaliser des audits de sécurité réguliers

- **Vulnérabilités corrigées :**
- **Ordre de priorité : Priorité 3/3**
- **Actions à réaliser :**
 - Effectuer des pentests annuels pour identifier les failles restantes.
 - Vérifier régulièrement les journaux d'audit et les configurations critiques.
 - Automatiser la détection des anomalies sur le réseau.
- **Ressources :**

Les vulnérabilités non détectées ou ignorées peuvent être exploitées par des attaquants. Un audit régulier permet de maintenir un niveau de sécurité élevé et d'identifier les

risques avant qu'ils ne deviennent des problèmes majeurs. Effectuer des audits de sécurité réguliers permet d'identifier et corriger les failles qui pourraient être exploitées par des attaquants.

En conclusion, la mise en œuvre de ces recommandations de sécurité permet non seulement de corriger les vulnérabilités actuelles, mais aussi de préparer la clinique de Frontignan à faire face aux défis futurs. En combinant des actions immédiates avec un plan d'action à long terme, l'objectif est de renforcer de manière continue la résilience du système d'information. Une gestion rigoureuse des accès, une sensibilisation constante des utilisateurs et des audits réguliers assurent une défense proactive contre les menaces. Il est essentiel de maintenir une culture de sécurité active et évolutive, capable de s'adapter aux nouvelles vulnérabilités et aux techniques d'attaque émergentes, garantissant ainsi la pérennité et la sécurité des ressources numériques de l'organisation.